

ABC Cloud Technologies Ltd.

Management Risk Report

Company Risk Assessment & ISO/IEC 27001 GRC Portfolio

Assessment Date: August 2026

Version: 1.0

CONFIDENTIAL — PORTFOLIO SIMULATION

1. Executive Summary

This report presents the management-level results of a simulated company risk assessment for ABC Cloud Technologies Ltd. The assessment follows a practical GRC workflow covering assets, risks, risk scoring, treatment planning, ISO/IEC 27001:2022 control mapping, audit evidence, findings, and corrective actions.

The assessment identified 12 priority risks. The most significant themes are unauthorized access to sensitive information, privileged-access governance, cloud configuration, application vulnerabilities, backup recoverability, identity security, and CI/CD security. Treatment plans have been defined for all identified risks.

A simulated internal audit review subsequently identified 15 evidence-review items. The portfolio demonstrates a mixture of passes, observations, and nonconformities. Corrective actions are tracked through a dedicated register with root cause, action owner, target date, evidence, and effectiveness verification.

Management message: The organization should prioritize identity and privileged-access controls, backup recovery validation, secure configuration monitoring, security monitoring, and secure software development. These areas have the strongest potential to reduce material information-security risk.

2. Assessment Scope

The simulated scope includes business information, customer information, applications, source code, cloud infrastructure, endpoints, identity services, collaboration platforms, backups, monitoring systems, remote-access services, and contractual records.

The assessment is designed as a professional portfolio exercise. It is not an actual certification audit, and all organization details, evidence, findings, scores, owners, and dates are simulated.

3. Risk Profile

Metric	Result
Risks assessed	12
Treatment actions	12
Treatment approach	Mitigate
Critical treatment actions	7
High treatment actions	5
ISO control mappings	22
Audit evidence reviews	15
Corrective actions	10

The risk treatment portfolio is currently action-oriented: every identified risk has a documented treatment action, owner, priority, target date, and expected residual-risk position.

4. Management Priority Risks

Priority	Risk Theme	Management Concern	Recommended Focus
1	Customer information access	Unauthorized access could expose sensitive customer data	Implement least privilege, access reviews, monitoring
2	Privileged access	Compromised privileged accounts could affect critical systems	Systemic certification, separate admin accounts, monitoring
3	Cloud configuration	Misconfiguration could expose production resources	Secure baseline, continuous monitoring, exception management
4	Backup & recovery	Backup failure or ransomware could disrupt recovery	Immutable backups, restore testing, recovery evidence

Priority	Risk Theme	Management Concern	Recommended Focus
5	Application security	Application vulnerabilities could compromise accounts	Secrets management, security testing, vulnerability remediation
6	CI/CD security	Pipeline compromise could introduce unauthorized pre-production changes	Separation of duties, secrets protection, logging

5. ISO/IEC 27001 Control Alignment

The risk treatment actions have been mapped to relevant ISO/IEC 27001:2022 Annex A controls. The mapping creates traceability between identified risks, treatment decisions, controls, and expected audit evidence.

Control	Example Management Relevance
A.5.15 Access control	Restrict access based on business need and least privilege.
A.5.16 Identity management	Manage identities through their lifecycle.
A.5.17 Authentication information	Protect credentials and strengthen authentication.
A.6.3 Security awareness	Reduce human-factor and phishing-related risk.
A.6.7 Remote working	Protect information accessed outside controlled premises.
A.8.2 Privileged access rights	Control and periodically review elevated access.
A.8.4 Access to source code	Protect source code from unauthorized access and changes.
A.8.8 Technical vulnerabilities	Identify, prioritize and remediate vulnerabilities.
A.8.9 Configuration management	Maintain secure and controlled system configurations.
A.8.13 Information backup	Maintain and test recoverability of information.
A.8.15 / A.8.16 Logging & monitoring	Support detection, investigation and response.
A.8.28 Secure coding	Embed security into software development.
A.8.31 Environment separation	Reduce unauthorized changes between environments.
A.8.32 Change management	Ensure controlled and traceable production changes.

Control applicability should be confirmed through the organization's risk assessment and Statement of Applicability. This portfolio mapping is illustrative and does not constitute an ISO certification conclusion.

6. Simulated Audit Results

The audit evidence register contains 15 simulated control reviews. The review identifies several areas where implementation evidence or operating effectiveness should be strengthened.

Area	Simulated Result	Management Response
Authentication	Observation / partial evidence	Complete MFA coverage and maintain exception approvals.
Cloud configuration	Minor nonconformity	Implement continuous configuration monitoring and exception management.
Backup	Major nonconformity	Formalize restore testing and retain recovery evidence.
Logging & monitoring	Observation / minor nonconformity	Formalize review cadence, alert tuning and escalation evidence.
Security awareness	Minor nonconformity	Implement recurring training and phishing-simulation tracking.
Secure coding	Minor nonconformity	Make applicable security testing a documented release gate.
Privileged access	Major nonconformity	Establish quarterly privileged-access certification.

7. Corrective Action Priorities

Ten corrective actions have been created from the simulated findings. Management should prioritize actions according to risk and potential business impact, rather than simply closing actions administratively.

Immediate priorities: privileged-access certification, MFA coverage, backup restore testing, cloud configuration monitoring, and monitoring/alert governance.

Secondary priorities: security awareness, source-code access certification, secure-development testing, environment privilege reviews, and evidence-retention improvements.

8. Management Recommendations

1. Establish quarterly management review of information-security risks, treatment progress, and overdue actions.
2. Treat privileged access and authentication as high-priority enterprise controls.
3. Validate recoverability through documented backup restoration exercises rather than relying only on successful backup-job reports.
4. Implement continuous or scheduled secure-configuration monitoring for cloud and production environments.
5. Integrate security testing and vulnerability remediation into the software-development lifecycle.
6. Strengthen security monitoring with defined use cases, alert severity, escalation criteria, and retained review evidence.
7. Maintain objective evidence for control operation so that management and auditors can verify effectiveness.
8. Link corrective-action closure to effectiveness verification, not merely completion of a task.

9. Management Decision / Sign-Off

Management should review the identified risks, approve treatment priorities and resources, confirm risk ownership, and accept or revise the proposed target dates. Any residual risk outside approved tolerance should be escalated through the organization's risk-acceptance process.

Role	Name	Decision / Signature	Date
Executive Sponsor			
Risk Owner			
IT / Security Lead			
Compliance / GRC Lead			

Document classification: Portfolio simulation / training artifact. Not an actual audit report or certification statement.